
Top 19 Active Directory Security Best Practices for IT Professionals

Key Takeaways

- Regular audits and real-time monitoring help identify vulnerabilities, unauthorized changes, and suspicious activity before they escalate into major security incidents.
- Strong authentication measures such as multi-factor authentication, complex password policies, and secure credential management significantly reduce the risk of account compromise.
- Limiting user privileges, securing administrator accounts, and controlling access through role-based permissions minimize the attack surface and prevent unauthorized access.
- Protecting domain controllers, service accounts, and critical Active Directory infrastructure with patching, segmentation, and hardening measures strengthens overall security.
- Backup and recovery planning, penetration testing, SIEM/EDR deployment, and incident response preparedness improve resilience against ransomware, breaches, and operational disruptions.

One of your organization's most essential components is Active Directory (AD). Here we'll look at some basic yet best practices for securing Active Directory infrastructure, backed up by statistics. As, in today's digital landscape, cyber threats lurk around every corner, protecting your organization's Active Directory infrastructure is more than a priority, it's a requirement.

What is Active Directory Security?

Active Directory Security refers to the strategies, configurations, and best practices used to protect an organization [Active Directory \(AD\)](#) from cyber threats and unauthorized access. As the backbone of identity and access management in Windows environments, AD controls user authentication, permissions, and network resources. A compromised AD can expose an entire network to security breaches, data theft, and operational disruptions.

To mitigate these risks, organizations must implement strong security measures, such as enforcing least privilege access, monitoring suspicious activity, applying regular patches, and following industry best practices. Proper Active Directory security ensures the integrity, availability, and confidentiality of your digital infrastructure, reducing vulnerabilities, and strengthening overall cybersecurity posture. The importance of securing Active Directory for cybersecurity cannot be overstated. Because Active Directory manages authentication, authorization, and access to critical business resources, attackers often target it first. A secure Active Directory environment helps protect sensitive data, [prevent unauthorized access](#), and strengthen overall cyber resilience.

Common Active Directory Security Risks

One of the most significant [security risks associated with Active Directory](#) is unauthorized access to accounts and systems. Attackers often target AD to gain access to sensitive data and critical systems. The theft of user credentials, such as usernames and passwords, is a common strategy for gaining unauthorized access. Once inside, attackers can move laterally across the network, [escalating privileges](#) and causing extensive damage. Compromising Active Directory can lead to severe consequences, including data breaches, financial losses, and reputational damage.

Therefore, understanding and mitigating these risks is crucial for maintaining a secure Active Directory environment. Now let's dive straight into the list of best practices.

Some of the most common Active Directory security issues include weak passwords, excessive user privileges, stale accounts, unsecured service accounts, outdated protocols such as SMBv1 and NTLM, poor monitoring practices, and misconfigured permissions. Identifying and addressing these issues early can significantly reduce security risks.

How to Secure Active Directory

If you are wondering how to secure Active Directory, the answer lies in combining strong access controls, continuous monitoring, privileged account protection, regular audits, and security awareness training. Organizations that follow proven Active Directory security best practices can reduce the risk of unauthorized access, data breaches, and [ransomware attacks](#) while maintaining a stronger cybersecurity posture.

Active Directory Security Concepts

Understanding key Active Directory security concepts is essential for protecting enterprise environments. These concepts include authentication, authorization, least privilege access, [role-based access control \(RBAC\)](#), privileged access management, identity governance, and continuous monitoring.

Organizations should also implement strong Active Directory security controls such as multi-factor authentication, auditing, privileged access management, endpoint protection, and network segmentation.

Some of the most important Active Directory security features include Group Policy, Kerberos authentication, security groups, access control lists (ACLs), auditing capabilities, and integration with modern security platforms.

Top 19 Active Directory Security Best Practices

Effective active directory management involves organizing and structuring user permissions and access rights, which is crucial for maintaining a secure network. This includes using groups for assigning privileges to ensure secure and efficient administration, as well as maintaining a minimal number of privileged users to adhere to security and compliance standards.

1. Regular Active Directory Assessments and Audits

Regular [Active Directory audits](#) and assessments are very important in securing your AD. They will give you an overall view of your present AD health and help you with any current security flaws, misconfigurations, vulnerabilities, or other footholds that attackers can use to gain access to your domain. During these audits, special attention should be given to securing domain admin accounts, as they hold significant privileges and are prime targets for attackers.

Advanced active directory auditing tools, like [Fidelis Active Directory Intercept](#)™, provide granular insight into areas such as user activities, group membership, and access rights. This level of knowledge enables you to make informed decisions about security controls and policy enforcement, thus ensuring your AD environment stays secure and compliant.

Regular [AD risk assessments](#) facilitate the identification of changes that might have occurred over time. It provides a chronological history of changes and their impact. The Granular audit

trail allows tracing any anomalies back to its point of origin, which helps in finding security breaches and unauthorized changes.

2. Continuous Monitoring

Cyber threats continue to get sophisticated, and the cost of data breaches are costing a very hefty price for businesses today, talking about \$4.45 million on average in 2023^[1], yes, a 15% growth in just three years! Yikes!

Don't worry, you can fight back! Continuously [monitoring your Active Directory](#) is like watching over your digital front door 24/7. This allows for the detection of suspicious activity in real-time, before it becomes a full-scale breach that drains the bank account of your company. Continuous monitoring helps in detecting attempts by bad actors at gaining access to sensitive data and privileged accounts.

Think of it this way: state-of-the-art monitoring technologies log every event on your network, at what time someone logs into it, and the applications they access, so that in the case of impersonation, you'll be able to trace suspicious activities and shut them off before they lead to some serious problem.

Advanced algorithms and [machine learning](#) in real-time monitoring systems analyze user behavior patterns and anomalies. This is a proactive approach that allows for the timely identification of potential threats and gives security teams the space to act on time, mitigating risks before they further escalate.

Watch Our Expert-Led Webinar
Safeguarding Active Directory in the Era of Cyber Threats

- Top Active Directory threats
- Learn how attackers gain access and how to prevent it
- Proactive strategies to strengthen your defenses

[Watch On-Demand Now](#)

Crack the Code: **Safeguarding Active Directory in the Era of Cyber Threats**

Watch Now



Rami Mizrahi

VP, Engineering,
Fidelis Security



Paul Girardi

Cybersecurity Advisor
Fidelis Security



Mike Hoffman

Cofounder and CEO,
SNOKE CONNECT



Robert Fuchs

VP International Services,
Fidelis Security



Nick Copeland

Senior System Engineer,
Fidelis Security

3. Create Strong Password Policies

Well, it is very well known that passwords are the very first and foremost defense, which prevents unauthorized access. In other words, companies should set up strong password policies covering all requirements, ranging from the minimum character length to the required character makeup. Strong passwords, in this case, make it quite difficult for attackers to bypass the system by [brute-force attacks](#). Using the same password for multiple accounts can significantly increase security risks, as compromising one account can lead to unauthorized access to others.

The password policy should involve upper- and lower-case letters, numbers, and special characters. Implementing password expiration policies and creating a barred list of old passwords can also be very prospective. Encourage users not to use common passwords and personal information.

4. Control Access Rights

The principle of least privilege is important in managing user access effectively. The users should be able to view only what is necessary for them to complete the job; nothing more, nothing less. Review the permission regularly and revise it as needed. This will help in [reducing the attack surface](#) area, thereby limiting the risk from compromised accounts.

Implement role-based access control (RBAC), and give access based on job responsibilities. Have regular audits and remove privileges not required to minimize unauthorized usage. Automate

access reviews to a certain extent so that reviews are done consistently and accurately.

5. Pay Special Attention to Privileged Accounts

Privileged accounts are the accounts that have advanced access to information in the system, such as service accounts and domain administrators. You must put strict rules around such accounts, like multifactor authentication, monitor sessions, and just-in-time access. Domain admins have extensive access to the entire domain and should not be used for day-to-day tasks to minimize security risks. At the same time, monitor all their activities closely, and in case you notice any suspicious activity, don't waste time, jump right into investigations.

Advanced management and monitoring of privileged accounts can be achieved through PAM solutions. Such solutions secure access workflows, session recording, automated credential management, logging, and auditing of privileged activities.

6. Lock Down Service Accounts

Service accounts pose a huge security risk but are normally overlooked. Advanced controls around them should be implemented, such as disabling interactive logon and delegation limitations. All permissions should, quite regularly, be reviewed to ensure the misuse of service accounts is prevented.

Managing local administrator accounts with unique passwords for each machine can mitigate security risks. These accounts should have very strong passwords that are changed regularly. This can be automated with password vaulting solutions to ensure that service accounts don't use default or easily guess credentials; it also provides periodic rotation of passwords. Monitor service account usage and retain records of this usage to detect unusual activity.

7. Active Directory Backup and Recovery

Even with great defenses, cyberattacks and unexpected events can impair your operations. According to the Acronis Cyber Protection Week Global Report[\[2\]](#), 76% of organizations suffered downtime because of data loss.

So, when you suffer a hit, that is the time when a rock-bound backup and recovery strategy for AD comes into play. Regular backups help in backing up the data quickly in the event of a disaster: data loss, data corruption, even from ransomware. This results in reduced downtime, and the organization will keep running smoothly.

Make sure that backups are not only completed but stored in a secure manner, with regular practice of testing for integrity and recoverability. Automated backup solutions are recommended, as they will minimize chances of human errors and ensure up-to-date backup. Offsite or cloud storage for backup can be considered to provide protection in the event of the result of physical disasters.

8. Domain Controller Best Practices

Secure the domain controllers; they are the pulse of Active Directory. Implement solid access controls, patch/upgrade frequently, and in the last quarter alone, 266% more infostealer [malware](#) variants have been recorded targeting login credentials[\[3\]](#)!

Domain controllers have extensive access to the entire domain, making them critical points secure against unauthorized access.

Here's how you can fight back against such attacks and secure your data:

- Apply more advanced access control. Give users only the access they need.
- Add another layer to protect against unauthorized access, like multi-factor authentication (MFA).
- Keep your domain controllers away from untrusted networks.
- Be continuously on the lookout for any suspicious activities being executed by your domain controllers.

Furthermore, keep the domain controllers physically secure and allow entry only to authorized personnel. Network segmentation must be in place that shall keep the domain controllers isolated within the network and restrict [lateral movement](#) in case of a breach.

9. Disable SMBv1 and Restrict NTLM

Many vulnerabilities are associated with the SMBv1 protocol and the NTLM mechanism. If you turn off SMBv1 and limit NTLM usage throughout the [AD forest](#) and domain, it's going to make it hard for attackers to exploit these vulnerabilities.

Needlessly, the risk of exploitation could be considerably reduced by just turning off SMBv1 on all systems. Configure the Group Policies to constrain NTLM and enforce much more secure authentication protocols like Kerberos. Regularly perform auditing on your network for systems that may still be running SMBv1 or NTLM.

10. Secure Active Directory User Management

As recently pointed out by a Forrester report, 22% of data breaches are from internal incidents, with 47% being intentional^[4]. This vindicates the need for strong Active Directory user management. Given these statistics, you should increase your defense by implementing strong user account management practices.

- Enforce the least privilege for users regarding their responsibilities.
- Implement monitoring of user activity and conduct a regular review of user permissions and update the same on the same.
- One of them is the automation of provisioning and deprovisioning for simplifying account administration and avoiding orphaned accounts or unauthorized access.

11. Leveraging Azure Active Directory

When you use cloud-based identity management systems like Azure Active Directory, you will be able to significantly improve scalability, flexibility, and security. According to a report by Gartner^[5], by 2025, most cloud security failures, around 99%, will stem from customer misconfigurations.

By seamlessly integrating [Azure Active Directory](#) with on-premises Active Directory environments, you can centralize user authentication, streamline identity management processes, and enforce consistent security policies across hybrid IT environments.

12. Enforcing Network Segmentation

You know, implementing network segmentation within your Active Directory setup can be a real gamechanger for your security strategy. By splitting your networked resources into different security zones and implementing strict access controls, you effectively create walls that limit the

reach of potential security risks.

This containment method [limits lateral movement within your network](#) and reduces unauthorized access to your sensitive data and resources.

So, by taking the time to implement network segmentation, you are effectively strengthening your defenses and lowering your organization's vulnerability to possible security threats. A wise decision with potential long-term benefits.

13. Conducting Regular Security Awareness Training

By training your team on cyber threats and cybersecurity best practices, you will be able to [prevent social engineering attacks](#) on Active Directory users. Through interactive training sessions, simulated phishing drills, and assessments, you enable your staff to detect and report suspicious activities, thereby enhancing the security of your Active Directory system.

It is all about providing your team with the knowledge and skills they require to stay aware and [safeguard your sensitive data](#) from potential security threats.

14. Use SID Filtering Across All Forest Trusts

To enhance the security measures, enable SID filtering across all the forest trusts. Security Identifier filtering prevents an attacker using credentials of one forest for accessing the other forest's resources. Only authenticated people can access cross-forest resources, and security is enhanced.

Basically, SID filtering involves configuration of the relationship of trust and making sure that SIDs from foreign forests are filtered. It shall review and update the trust configurations sometimes for enhanced security toward avoiding unauthorized access.

15. Perform Regular Penetration Testing

Penetration testing should be done regularly to [detect vulnerabilities](#) and weaknesses within your Active Directory environment. This will help in simulating attacks that are as close to real attacks as possible, estimating security posture, and working further on improvements.

Allow professional security firms to conduct end-to-end penetration tests and provide detailed reports on the findings. Use such kinds of testing for insight into the strengthening of defenses and for resolving quickly any identified vulnerabilities.

16. Use Security Information and Event Management (SIEM)

Implement SIEM solutions that collect, analyze, and correlate security events from AD and other sources to be able to identify potential security incidents in real-time and respond swiftly to mitigate risks.

Modern Active Directory security solutions help organizations identify threats, monitor user activity, protect privileged accounts, and respond to attacks in real time. Security teams often use a combination of SIEM, [EDR](#), privileged access management (PAM), identity threat detection, and auditing tools to strengthen Active Directory defenses.

17. Establish a Strong Incident Response Plan

Develop and maintain a comprehensive [incident response plan](#) specific to security incidents in Active Directory. An organization needs to develop a plan explaining the procedures to act upon in case of a security breach, therefore managing quick responses to security incidents with minimal damage.

- **Suggested Reading: Active Directory Incident Response: Key Things to Keep in Mind**

18. Implement Endpoint Detection and Response (EDR)

[Endpoint Detection and Response solutions](#) Provide advanced threat detection and response at the endpoint level. EDR solutions involve continuous detection of events coming from endpoints to provide rapid threat detection and response.

Endpoint Detection and Response will enhance your security posture by giving you [real-time visibility at the Endpoint level](#) and letting automated response actions occur. Keep updating and tuning regularly to make sure your EDR solutions are detecting and mitigating evolving threats.

19. System Hardening

Run only supported operating systems and keep them updated

Ensuring that your Active Directory environment runs only on supported operating systems and keeping them updated is a fundamental security practice. Unsupported operating systems do not receive security updates and patches, making them vulnerable to attacks. Regularly updating your operating systems ensures that you have the latest security features and patches, protecting your network from potential threats.

Additionally, consider implementing the following best practices to further harden your system:

1. **Use a Secure Admin Workstation (SAW):** Designate a secure workstation for administrative tasks to minimize the risk of compromise.
2. **Disable the Local Administrator Account:** On all computers, disable the local administrator account to prevent unauthorized access.
3. **Implement Local Administrator Password Solution (LAPS):** Use LAPS to manage local admin passwords securely, ensuring they are unique and regularly updated.
4. **Enable Audit Policy Settings:** Use group policy to enable audit policy settings, allowing you to monitor security events effectively.
5. **Monitor Active Directory:** Continuously monitor Active Directory for signs of compromise, using advanced tools and techniques.
6. **Use Descriptive Security Group Names:** Manage permissions effectively by using descriptive names for security groups.
7. **Adopt Passphrases:** Encourage the use of passphrases instead of traditional passwords for better security. Passphrases should be a minimum of 12 characters and easy for users to remember but hard for attackers to guess.

By implementing these best practices, you can significantly reduce the risk of security breaches and enhance the resilience of your Active Directory environment.

- Statistics and Trends
- Beyond Security Checklist
- Multi-Layered Defense

[Get the Checklist Now](#)



The image displays a promotional graphic for a white paper by Fidelis Security. The top left features the Fidelis Security logo. Below it, the title "Security Checklist" is visible. The main focus is a large, dark blue tilted rectangle representing the white paper cover, which contains the text "WHITE PAPER" and "Security Checklist: Hardening Your Active Directory with Advanced Strategies" in orange and white. To the left of this rectangle, a preview of the white paper's content is shown, including the section "Beyond the Checklist" and a list of advanced strategies.

Security Checklist

Beyond the Checklist

While the provided security layered approach that goes into these strategies:

- **Segmentation and Area Networks** or compartmentalized. Consider the Purdue with multiple network resources. This is after compromising.
- **Just-In-Time (JIT)** the minimum level accounts, as compared to Just-In-Time (JIT) Management (JITM). With JIT, elevate significantly minimize damage if a privilege is compromised.
- **Deception Technology** – strong attackers away. By monitoring and which will allow.
- **Continuous Security** evolving threat implementing can centralized centralized via potential threat. However, relying hunting comes actively search potential threat.
- **Privileged Access** They hold the solution is designed to.

✓ Enable
✓ Role
✓ Monitor

By implementing multi-layered defense, vigilance and add

Copyright © 2024 Fidelis Security LLC. All rights reserved. www.fidelissecurity.com 8

Best Practices Summary Table

Security Measure Tactical or Strategic Preventative or Detective Regular Active Directory Assessments and Audits Strategic Detective Continuous Monitoring Tactical Detective Create Strong Password Policies Tactical Preventative Control Access Rights Tactical Preventative Attention to Privileged Accounts Tactical Preventative Lock Down Service Accounts Tactical Preventative Active Directory Backup and Recovery Strategic Preventative Domain Controller Best Practices Tactical Preventative Disable SMBv1 and Restrict NTLM Tactical Preventative Secure Active Directory User Management Tactical Preventative Leveraging Azure Active Directory Strategic Preventative Enforcing Network Segmentation Strategic Preventative Conducting Regular Security Awareness Training Strategic Preventative Use SID Filtering Across All Forest Trusts Tactical Preventative Perform Regular Penetration Testing Tactical Tactical Detective Use Security Information and Event Management (SIEM) Strategic Detective Establish a Strong Incident Response Plan Strategic Preventative Implement Endpoint Detection and Response (EDR) Strategic Detective

Securing Your Active Directory Environment

Securing your organization's Active Directory environment is important if you want to secure your digital assets and [maintain operational resilience](#). By implementing the mentioned practices, you can significantly enhance the security posture of your AD environment and bring down the risk of security breaches and data loss. Remember, cybersecurity is a journey, not a destination. You should keep up to date with emerging threats and vulnerabilities and regularly review and update your security controls and practices, so you can stay one step ahead of cyber threats.

Citations:

1. [^https://www.ibm.com/reports/data-breach](https://www.ibm.com/reports/data-breach)
2. [^Acronis Cyber Protection Week Global Report](#)
3. [^IBM X-Force 2025 Threat Intelligence Index](#)
4. [^Internal Incidents Cause Almost A Quarter Of Breaches, With More Than Half Intentional](#)
5. [^https://www.gartner.com/smarterwithgartner/is-the-cloud-secure](https://www.gartner.com/smarterwithgartner/is-the-cloud-secure)